NEXUS FINANCIAL

Incident Response Policy

Version: 2.3 | Classification: Internal Confidential
Prepared by: Linda Osei, SOC Manager
Approved by: Margaret Ellis, Chief Information Officer
Date: March 2026 | Review Date: March 2027

1. Purpose

This policy defines Nexus Financial's approach to managing cyber security incidents. It establishes the responsibilities of the Cyber Security Incident Response Team (CSIRT), the procedures to follow when an incident is suspected or confirmed, and the standards for documentation and communication throughout the incident response process.

2. Scope

This policy applies to all employees, contractors, and third parties who access Nexus Financial systems, data, or infrastructure. It covers all information assets including on-premises systems, cloud platforms, and remote access environments.

3. Incident Definition

A security incident is defined as any confirmed or suspected violation of Nexus Financial's security policies that results in, or has the potential to result in, unauthorised access to, disclosure of, or disruption to company systems or data.

Examples of events that may constitute a security incident:

• Unauthorised access to a user account or system

• Malware infection on any company device or platform

• Data exfiltration or suspected data breach

• Phishing attack resulting in credential compromise

• Denial of service attack on company infrastructure

• Insider threat activity

4. Security Operations and Detection

Nexus Financial operates a Security Operations function led by the SOC Manager. The SOC team is responsible for monitoring alerts generated by the SIEM platform, triaging suspicious activity, and escalating confirmed or suspected incidents to the CSIRT.

The SIEM platform is configured with detection rules covering a range of threat scenarios. These rules are reviewed and updated quarterly by the SOC Manager in collaboration with the IT Administrator.

NOTE: The current detection rule set does not cover all threat scenarios.

Gaps in coverage include inbox rule creation on cloud mail platforms, bulk file downloads from SharePoint, and sign-ins from new geographic locations. These gaps have been flagged for remediation but have not yet been addressed as of the date of this policy.

5. Incident Severity Classification

All incidents must be classified upon declaration:

Severity	Description	Example
CRITICAL	Immediate threat to core business operations or sensitive data at scale.	Active ransomware, confirmed data breach affecting client PII.
HIGH	Significant threat with potential for major impact if not contained quickly.	Confirmed account compromise with evidence of malicious activity.
MEDIUM	Potential threat requiring investigation and monitoring.	Suspicious sign-in activity, phishing email reported.
LOW	Minor event with limited potential impact.	Failed login attempts, spam campaign.

6. Roles and Responsibilities

Name / Role	Responsibilities
Linda Osei SOC Manager / CSIRT Lead	Leads the incident response process. Coordinates CSIRT members. Authorises containment actions.
Marcus Webb Security Analyst	Monitors SIEM alerts. Performs initial triage. Escalates confirmed incidents to CSIRT Lead.
David Soto IT Administrator	Provides technical access and infrastructure support during investigations.
Margaret Ellis Chief Information Officer	Notified for High and Critical incidents. Approves external communications.
Rachel Thompson Legal Counsel	Notified if incident involves potential data breach or regulatory implications.

All employees must report suspected incidents to the SOC team immediately via security@nexusfinancial.com.

7. Incident Response Phases

Nexus Financial follows the NIST SP 800-61 incident response framework:

Phase	Purpose
Phase 1: Preparation	Ensuring the organisation is ready to respond.
Phase 2: Detection and Analysis	Identifying and confirming the incident and its scope.
Phase 3: Containment, Eradication, and Recovery	Limiting damage, removing the threat, restoring operations.
Phase 4: Post-Incident Activity	Documenting lessons learned and improving defences.

8. Communication and Escalation

All communications during an active incident must be coordinated through the CSIRT Lead. External communications must be approved by the CIO before being issued.

NOTE: This policy does not currently define a maximum response time between incident declaration and initial containment action. This gap has been flagged for remediation in Q2 2026 but has not yet been addressed.

9. Evidence Handling

All evidence collected during an incident must be handled in accordance with the Nexus Financial chain of custody procedures. Evidence must not be modified, deleted, or moved without written authorisation from the CSIRT Lead.

10. Policy Review

This policy must be reviewed annually or following any significant security incident. Updates must be approved by the CIO and communicated to all CSIRT members within 14 days of approval.

11. Related Documents

- Nexus Financial Communication Plan
- Nexus Financial Asset Inventory
- Nexus Financial Historic Incidents Log
- NIST SP 800-61 Computer Security Incident Handling Guide

End of Document